

Contenido

FASE DE RECONOCIMIENTO:	4
<i>Herramientas a usar en reconocimiento pasivo:</i>	5
<i>Herramientas a usar en reconocimiento activo:</i>	5
<i>Escaneo de puertos y servicios con Nmap</i>	5
<i>Tipos de enumeración:</i>	8
<i>Enumeración de hosts</i>	8
<i>Enumeración de usuarios</i>	8
<i>Enumeración de grupos</i>	10
<i>Enumeración de recursos compartidos de red</i>	10
<i>Ejemplos de enumeración de SMB adicionales</i>	10
<i>Enumeración de páginas web / Enumeración de aplicaciones web</i>	11
<i>Enumeración de servicios</i>	11
<i>Exploración de la enumeración a través de la elaboración de paquetes con Scapy</i>	11
<i>Inspección y escucha de paquetes</i>	12
<i>Funcionamiento de un escáner automatizado de vulnerabilidades</i>	12
<i>Tipos de análisis de vulnerabilidades</i>	12
<i>Reenvío SSH</i>	13
ATAQUES DE INGENIERÍA SOCIAL:	15
<i>Ataques Físicos</i>	17
<i>Tools para Ingeniería Social</i>	17
<i>Tools para el Phishing Telefónico</i>	18
<i>Técnicas / métodos de influencia de la ingeniería social para obtener más información</i>	18
EXPLOTACIÓN DE REDES CABLEADAS E INALÁMBRICAS:	18
<i>Tipos de explotaciones de Red</i>	19
<i>Resolución de nombres de Windows y ataques de SMB</i>	19
<i>NetBIOS</i>	19
<i>NetBIOS ofrece tres servicios diferentes</i>	20
<i>Puertos usados por NetBIOS para realizar operaciones</i>	20
<i>LLMNR</i>	20

Grupo de trabajo y Dominios	20
Aprovechamiento de vulnerabilidades en NetBIOS, SMB y LLMNR.....	20
Explotaciones para SMB	21
Envenenamiento de la caché de DNS	21
Explotaciones de SNMP	21
Explotaciones de SMTP	22
Open Relay en SMTP.....	22
Comandos útiles para usar con estos servidores	22
Tool para evaluar un servidor SMTF.....	23
Explotaciones de FTP	23
Ataques de tipo Pass-the-Hash	24
Ataques basados en Kerberos y LDAP	24
Pasos de la autenticación en Kerberos	25
LDAP	25
Ataque Golden Ticket	25
Ataque Silver Ticket.....	26
Delegación de Kerberos	26
Kerberoasting	27
Ataques en Ruta (MITM).....	27
Suplantación ARP y envenenamiento de caché ARP	27
Ataques de degradación	28
Ataques de manipulación de rutas	28
Ataques DoS y DDoS.....	28
Omisión del control de acceso a la red (NAC)	29
Salto de VLAN (VLAN Hopping).....	29
Ataques de inanición de DHCP y servidores DHCP no autorizados	31
Aprovechamiento de las vulnerabilidades inalámbricas.....	31
Puntos de acceso no autorizados	31
Ataques de gemelos malvados (Evil Twin Attack)	31
Ataques de disociación (o desautenticación).....	31
Ataques a la lista de redes preferidas	32
Interferencia y bloqueo de la señal inalámbrica	32

<i>Conducción de guerra</i>	32
<i>Ataques por vector de inicialización (IV) y protocolos inalámbricos no seguros</i>	32
<i>Ataques de KARMA</i>	33
<i>Ataques de fragmentación</i>	34
<i>Recopilación de credenciales</i>	34
<i>Bluejacking y Bluesnarfing</i>	34
<i>Ataques de Bluetooth de baja energía (BLE)</i>	34
<i>Ataques de identificación por radiofrecuencia (RFID)</i>	35
<i>Difusión de contraseñas</i>	35
<i>Encadenamiento de explotaciones</i>	35
EXPLOTANDO VULNERABILIDADES BASADAS EN APLICACIONES	35
<i>Estructura HTTP</i>	35
<i>Estructura de URL HTTP</i>	36
<i>API RESTful y SOAP</i>	37
<i>CURL</i>	37
<i>Tipos de ID de Sesión</i>	38
<i>Cookies</i>	38
<i>Fallas de la Lógica Empresarial</i>	38
<i>Vulnerabilidades basadas en inyección</i>	38
<i>Vulnerabilidades Basadas en la Autenticación</i>	39
<i>Ataques de Redireccionamiento</i>	40
<i>Credenciales Predeterminadas</i>	40
<i>Vulnerabilidades de Kerberos</i>	40
<i>Vulnerabilidades de autorización</i>	41
<i>Contaminación de Parámetros</i>	41
<i>Vulnerabilidades de Referencias Directas Inseguras a Objetos</i>	41
XSS	41
<i>DOM</i>	42
<i>CSRF/XSRF</i>	42
<i>Clickjacking</i>	42
<i>Recorrido de Directorios (Path Traversal)</i>	42
<i>Manipulación de Cookies</i>	43

FASE DE RECONOCIMIENTO:

El objetivo de esta fase es el escaneo y enumeración.

Reconocimiento pasivo => no se interactúa directamente con el objetivo, el fin de esta investigación es:

- a - Enumerar dominios y subdominios.
- b - Inspeccionar paquetes (preferentemente capturados con Wireshark).
- c - OSINT (ideal para recopilar PII [Información de Identificación Personal] y crear ataques de ingeniería social).
- d - Recon-ng
- e - Intercepción pasiva de la comunicación.

Reconocimiento activo => interactuar con el objetivo con el fin de lograr:

- a - Enumeración de redes.
- b - Enumeración de hosts. => lo primero que se tiene que hacer
- c - Enumeración de grupos.
- d - Enumeración de usuarios.
- e - Enumeración de recursos compartidos de red.
- f - Enumeración de páginas web.
- g - Enumeración de aplicaciones.
- h - Enumeración de servicios.
- i - Elaboración de paquetes.

Herramientas a usar en reconocimiento pasivo:

- **Nmap** => escaneo activo de hosts en busca de enumerar redes, hosts, servicios, OS y demás.
- **nslookup** => enumeración de hosts vinculados a un dominio y otro tipo de información relacionada a este.
- **whois** => actualmente es difícil que obtengamos algo verdadero de su uso pero siempre vale la pena usarla para obtener detalles técnicos y administrativos privados, dicha herramienta viene integrada en Recon-ng.
- **Analizar información de los certificados a través de un navegador** => mediante la transparencia de los certificados, se puede obtener información valiosa acerca del objetivo, como el número de serie, el período de validez y la información de la clave pública (como el algoritmo y periodo de validez) y ver si hay fallas criptográficas. También se pueden enumerar dominios, subdominios y otros sistemas.
- **https://crt.sh/** => para analizar la CT (transparencia de certificados) de cualquier dominio y enumerar posibles subdominios e información adicional.
- **ssllscan** => escanea un dominio para identificar cifrados y configuración SSL.
- **h8mail** => para obtener información sobre un correo electrónico y su contraseña en caso de haber sido expuesta.
- **ExifTool** => analiza información exif de imágenes, sonidos o archivos multimedia.
- **Gemini** => para usar Deep Research con IA y obtener información importante mucho más rápido.
- **Shodan** => buscador que muestra información de dispositivos de IoT y otros sistemas expuestos en la red como servidores, dominios, subdominios, bases de datos, etc que venimos descubriendo usando las tools anteriores.

Herramientas a usar en reconocimiento activo:

Escaneo de puertos y servicios con Nmap:

a - **Escaneo SYN (-sS)** => se manda un paquete SYN al puerto objetivo y según la respuesta del objetivo podemos concluir que:

- Abierto => si hay una respuesta TCP SYN-ACK
- Cerrado => TCP RST
- Filtrado => sin respuesta, puede haber un firewall protegiendo el puerto

Este escaneo no finaliza el Three-way handshake y genera mucho menos tráfico.

SYN → PUERTO 'X'

← SYN ACK

RST →

b - **Escaneo de conexión TCP (-sT)** => usa conexión TCP y por lo tanto crea mucho tráfico, se debe considerar como última alternativa en caso de no poder usar el escaneo SYN, como por ejemplo cuando no hay acceso root en el sistema desde el cual se está realizando el escaneo con Nmap:

- Abierto => si hay respuesta SYN/ACK de TCP
- Cerrado => TCP RST
- Filtrado => sin respuesta, puede haber un firewall protegiendo el puerto

SYN → PUERTO 'X'

← SYN ACK

ASK →

RST →

c - **Escaneo de UDP (-sU)** => para escaneos a servidores DNS, SNMP, DHCP; básicamente a sistemas que usan UDP en vez de TCP

- Abierto => los datos son devueltos por el puerto
- Cerrado => tenemos un mensaje de error ICMP
- Filtrado/Abierto => sin respuesta ICMP del objetivo

UDP a PUERTO 'X' →

← UDP a PUERTO 'X' CON DATA

d - **Escaneo FIN de TCP (-sF)** => cuando un firewall o filtro de red detecta un escaneo, esta opción podría ser considerada siempre y cuando el objetivo no sea un host Windows ya que independientemente del estado del puerto, va a devolver una respuesta con un paquete RST.

- Filtrado => se recibe un mensaje ICMP unattainable (inalcanzable), o sea responde con un paquete RST
- Cerrado => se recibe un paquete RST
- Abierto/Filtrado => no hay respuesta ya que descarta el paquete FIN enviado durante el sondeo.

Abierto/Filtrado:

FIN a PUERTO 'X' →

← NO HAY RESPUESTA

Cerrado/Filtrado:

FIN a PUERTO 'X' →

← RST

e - **Escaneos de detección de host (-sn):**

Este escaneo es para mapear/enumerar hosts en una determinada red de la siguiente forma:

Manda al objetivo los siguientes mensajes

eco ICMP →

TCP SYN al puerto 443 →

TCP ACK al puerto 80 →

Marca de solicitud de tiempo ICMP →

Si el objetivo responde a uno de estos, lo considera activo y lo mapea/enumerar. Este tipo de escaneo también se lo conoce como '***Barrido de ping***'

f - **Opciones de tiempo (-T 0-5):**

Este escaneo consta de 6 plantillas de temporización que Nmap usa, las mismas sirven para determinar el nivel de agresividad del escaneo:

- **-T0 (Paranoico):** muy lento, se usa para la evasión de IDS.
- **-T1 (Furtivo):** bastante lento, se usa para la evasión de IDS.
- **-T2 (Educado):** se ralentiza para consumir menos ancho de banda, se ejecuta aproximadamente 10 veces más lento que el valor predeterminado.
- **-T3 (Normal):** predeterminado, un modelo de tiempo dinámico basado en la capacidad de respuesta del objetivo.
- **-T4 (Agresivo):** supone una red rápida y confiable y puede abrumar a los objetivos.
- **-T5 (Demente):** muy agresivo; probablemente abrumará a los objetivos o perderá los puertos abiertos.

Tipos de enumeración:

Enumeración de hosts: es la primer tarea que se debe hacer en la fase de reconocimiento, se debe realizar tanto interna como externamente; cuando se realiza una enumeración externa, hay que limitar el rango de IPs a escanear y mantenerse dentro del scope establecido para evitar problemas o escanear cosas que no se deben.

Un escaneo interno se realiza solo a redes y subredes internas de una empresa y abarca a los hosts pertenecientes a estas.

Las herramientas usadas para realizar esta enumeración es Nmap o Masscan, aunque los escáneres de vulnerabilidades también realizan esto.

Enumeración de usuarios: el objetivo es hacer una lista de usuarios para descifrar sus credenciales a través de fuerza bruta usando tools como Hydra. Este tipo de enumeración se realiza cuando tenemos acceso a una red interna.

En una red Windows => se hace manipulando el protocolo SMB el cual usa el puerto 445

Funcionamiento de SMB:

SMB_COM_NEGOTIATE (Request) →

El cliente SMB le va a indicar al servidor SMB los protocolos, indicadores y opciones le gustaría usar.

← SMB_COM_NEGOTIATE (Response)

El servidor responde con una oferta sobre qué protocolos, indicadores y opciones prefiere el cliente. Esta información se puede configurar desde el mismo servidor SMB pero si se hace mal, generaría problemas y daría a conocer información confidencial, por ejemplo, si se configura que el servidor no requiera la firma de mensajes SMB (SMB Signing), se podría permitir que un atacante modifique el tráfico SMB en tránsito (ataques Man-in-the-Middle o Relay [reenvío de credenciales]). Si bien esto no significa que el servidor directamente permita contraseñas en texto plano en la negociación (SMB generalmente usa hashes como NTLMv2 o NTLM para las contraseñas), la falta de firma hace que el servidor sea vulnerable a la manipulación de los datos y la suplantación de identidad en sesiones autenticadas.

La respuesta del servidor también transmite información interesante como la hora y la zona horaria.

SMB_COM_SESSION_SETUP_ANDX (Request) →

Este es el proceso de autenticación, este mensaje incluye el nombre de usuario, la contraseña y el dominio del cliente. Si esta información no está cifrada, sería fácil de

interceptar. Si el mecanismo de cifrado es débil, cuando se intercepte sería fácil de descifrar fuera de línea con tools como Lanman y NTLM.

Con Nmap se puede manipular este mensaje enviando paquetes SMB_COM_SESSION_SETUP_ANDX (intentos de autenticación) al objetivo para analizar las respuestas:

```
nmap --script smb-enum-users.nse <IP_host>
```

Resultado del script:

Host script results:

smb-enum-users:

VULNHOST-1\derek (RID: 1000) => usuario descubierto

Full name:

Description:

Flags: Normal user account

← ***SMB_COM_SESSION_SETUP_ANDX (Response)***

Este mensaje es la confirmación del servidor SMB que indica el éxito o fracaso de la autenticación de un usuario y establece una sesión para ese usuario en caso de que las credenciales sean válidas.

SMB_COM_TREE_CONNECT_ANDX (Request)→

Es el comando que envía un cliente SMB para solicitar una conexión a un recurso compartido específico en el servidor (como una carpeta compartida, una impresora o un "pipe/tubería" de IPC\$ [que es un recurso compartido (un "share") por defecto que se usa para establecer conexiones a named pipes]).

Los atacantes a menudo se conectan a IPC\$ para acceder a servicios remotos que exponen interfaces a través de named pipes, como el "pipe" netlogon para enumerar usuarios o el "pipe" svcctl para manipular servicios.

Entonces, en resumen, un "pipe" (especialmente un "named pipe" en SMB) es un canal de comunicación entre programas, y en el contexto de la ciberseguridad, puede ser un punto de entrada o una forma de interactuar con servicios internos del sistema objetivo.

← ***SMB_COM_TREE_CONNECT_ANDX (Response)***

Es la confirmación del servidor SMB que indica si la conexión a un recurso compartido específico (como una carpeta o una impresora) fue exitosa o no, y en caso de éxito, proporciona detalles sobre la conexión establecida a ese recurso.

Enumeración de grupos:

Este tipo de enumeración es útil para determinar los roles de autorización que se utilizan en el entorno de destino. Un script de Nmap para llevar a cabo esto es el siguiente:

```
nmap --script smb-enum-groups.nse -p445 <host>
```

Este script va a intentar extraer una lista de grupos de una máquina Windows y los users de cada grupo.

La lista aparecerá debajo del apartado '**smb-enum-groups:**' y el orden será el siguiente:
[grupo] [usuarios]

Enumeración de recursos compartidos de red:

Va a mapear/enumerar los sistemas que hay en una red que están compartiendo archivos, carpetas e impresoras con el objetivo de ir desarrollando una zona de ataque.

Nmap tiene un script para llevar a cabo esta enumeración:

```
nmap --script smb-enum-shares.nse -p 445 <host>
```

La lista aparecerá debajo del apartado '**smb-enum-shares:**' y el orden será el siguiente:
account-used: [name]

\\<IP> \ [Recurso o Servicio ofrecido como IPC\$]:

[Información]:

Ejemplos de enumeración de SMB adicionales:

Para enumeración y huellas digitales adicionales, Nmap ofrece el siguiente comando:

nmap -sC <IP> => ejecuta los scripts NSE (Nmap Scripting Engine) más comunes según los puertos abiertos en el sistema o indicados en el script.

enum4linux => tool para enumerar los recursos compartidos de Samba, incluidas las cuentas de usuario, los recursos compartidos y otras configuraciones. Su sintaxis básica es la siguiente: **enum4linux <IP>**

smbclient => tool que enumera recursos compartidos y muestra más información sobre un sistema que ejecuta SMB. Su sintaxis básica es la siguiente: **smbclient -L \\IP**

Enumeración de páginas web / Enumeración de aplicaciones web

Una vez identificado un host que hace de servidor web, el siguiente paso es analizar el servicio web que ofrece para mapear la superficie de ataque a través de una enumeración de páginas web.

Nmap tiene un script NSE para la enumeración de aplicaciones web que va a intentar mostrar rutas o directorios interesantes.

```
nmap -sV --script=http-enum <target>
```

La lista aparecerá debajo del apartado '**http-enum:**'

Nikto => es otra herramienta para la enumeración de sitios web pero es muy ruidoso.

Su sintaxis básica es la siguiente: **nikto -h <ip_target>**

Enumeración de servicios:

Esta enumeración sirve para identificar los servicios que corren en un host determinado escaneando sus puertos abiertos.

Nmap tiene un script para enumerar servicios SMB de Windows mediante credenciales de un usuario que tiene acceso para leer el estado de los servicios en ejecución.

```
nmap --script smb-enum-processes.nse --script-args smbusername=<username>,  
smbpass=<password> -p445 <host>
```

Como se mencionó anteriormente, hay que usar credenciales de usuarios para poder hacer uso de este script de Nmap.

Exploración de la enumeración a través de la elaboración de paquetes con Scapy:

Scapy es un framework basado en Python para generar paquetes. Siempre debe ejecutarse con permisos de root => **sudo scapy**

Ejemplos de uso:

Paquete ICMP con un payload malicioso =>

```
send(IP(dst="192.168.0.251")/ICMP()/"malicious_payload")
```

La herramienta de captura de paquetes **tshark** se utiliza para capturar el paquete ICMP diseñado => **sudo tshark host <IP_atacante>**

Otros comandos para Scapy:

ls () => muestra los protocolos y formatos disponibles en Scapy.

ls (Protocolo) => muestra información específica del protocolo agregado entre los paréntesis.

explore () => para ver los protocolos y capas de Scapy.

explore (Protocolo) => para ver los protocolos y capas contenidas en Scapy de un protocolo o formato específico.

ans, unans = sr(IP(dst='192.168.88.251')/TCP(dport=445,flags='S')) => Escaneo TCP SYN, se pueden capturar con el comando de tshark de antes. Se envía un paquete SYN del puerto TCP 445 al host con la dirección IP 192.168.88.251.

Inspección y escucha de paquetes:

Tools recomendadas para interceptar, inspeccionar y ver paquetes son Wireshark, Tshark y tcpdump. Son ideales para un reconocimiento pasivo aunque se requiere de una conexión física o inalámbrica con el objetivo.

Para evitar la detección es recomendable conectarnos a la red de forma inalámbrica ya que no hace falta estar físicamente dentro de la red.

Funcionamiento de un escáner automatizado de vulnerabilidades:

- 1 _ La primera fase es la del mapeo de hosts y puertos en una red, el escáner usa una herramienta tipo Nmap para la enumeración.
- 2_ Una vez tenga el mapeado, sondea los puertos abiertos de cada host con el fin de recopilar más información sobre los servicios que corren en cada uno y su versión.
- 3_ Luego, compara la versión del software que está corriendo en cada puerto y lo compara con una base de datos interna que tiene para ver si no coincide con una vulnerabilidad conocida.
- 4_ Por último, con toda la información que recopiló, crea un informe con las vulnerabilidades descubiertas. Hay que tener muy en cuenta que muchas veces suelen ser falsos positivos, por lo que manualmente hay que corroborar que dichos hallazgos sean verdaderos y no falsos positivos.

Tipos de análisis de vulnerabilidades:

El tipo de escaneo dependerá de la política por defecto o la creada en cada escáner de vulnerabilidades, para elegir el escaneo ideal hay que tener en cuenta la infraestructura que se va a analizar ya que no siempre se podrá realizar un análisis completo de todos los dispositivos en una red ya que muchas veces habrá cuales no lo soporten y fallen, y otras veces directamente no se podrá hacer por el hecho de estar en un entorno de producción.

Dicho esto, algunas opciones de escaneo típicas son:

Escaneos no autenticados => este tipo de escaneo se realiza sin credenciales pero puede aportar menos información o descubrimiento que un escaneo autenticado. Solo

va a mostrar servicios que estén expuestos en la red, por lo que si el puerto que ofrece un servicio no está escuchando en el mismo segmento de red donde está el escáner o tiene un cortafuegos (firewall) que lo protege y aparecerá como cerrado el puerto cuando no lo está. A veces es posible acceder a puertos que no están expuestos a la red a través del reenvío de puertos SSH y otros trucos.

Reenvío SSH: Se lo conoce también como Reenvío de Puertos SSH (o SSH Port Forwarding / SSH Tunneling), permite acceder a servicios o puertos que no están directamente expuestos a la red desde tu máquina de ataque. Básicamente creo un túnel seguro que conecta a un puerto corriendo un servicio específico mediante SSH.

La idea es tener acceso a un servidor SSH y que este, a su vez, pueda ver un servicio corriendo en otra máquina (la objetivo por ejemplo) que nosotros no.

De esta forma, se usaría como puente este servicio SSH para llegar al servicio de la máquina objetivo.

Hay tres tipos de reenvío:

1_ Reenvío de Puertos Local (-L o Local Port Forwarding):

Es la forma más común de llevar a cabo esta técnica, consiste en mapear un puerto local (uno mío) con un puerto remoto objetivo pasando a través del servidor SSH para acceder al servicio que queramos como si estuviera corriendo en mi máquina.

Por ejemplo, supongamos que un servidor SSH tiene acceso a un servidor MySQL (puerto 3306) en la IP 192.168.1.50, pero mi máquina no puede ver esa IP porque no estoy en la red interna.

```
ssh -L 8000:192.168.1.50:3306 usuario@Servidor_SSH
```

Cuando desde mi máquina ejecute este comando, si accedo a **localhost:8000**, esa conexión será redirigida a través del túnel SSH hasta el Servidor SSH, y desde ahí, al puerto 3306 de 192.168.1.50 logrando parecer que **192.168.1.50:3306** estuviera corriendo en mi **localhost:8000**.

2_ Reenvío de Puertos Remoto (-R o Remote Port Forwarding):

Cuando mapeo un puerto remoto (del servidor SSH) a un puerto local (mi máquina local o remota). Este método es menos común que el anterior pero es útil para mantener persistencia o para que otra persona o yo de forma remota, acceda a un servicio de mi máquina o de la víctima a través del servidor SSH.

Esto es útil si quisiera exponer un servicio de mi máquina a la red del servidor SSH mediante un servidor web en el puerto 8080 por ejemplo.

```
ssh -R 9000:localhost:8080 usuario@Servidor_SSH
```

Al ejecutar el comando anterior, cualquier máquina que esté dentro de la red del servidor SSH y se conecte a este, será redirigido a mi máquina **localhost:8080**.

3_ Reenvío de Puertos Dinámico (-D o Dynamic Port Forwarding / SOCKS Proxy):

Este método crea un Proxy SOCKS en mi máquina. Un proxy SOCKS es un intermediario que enruta tu tráfico a través de un servidor para ocultar mi IP y mejorar el acceso a redes restringidas. Toda aplicación configurada para usar este proxy SOCKS enviará su tráfico a través del túnel SSH.

Es una técnica muy potente ya que 'proxyfica' el tráfico generado por mí y mis herramientas como Nmap a través del servidor SSH hacia la red interna. Esto hace que yo no mapee un puerto en específico sino que uso el túnel SSH como punto de pivoting general.

```
ssh -D 1080 usuario@Servidor_SSH
```

Ejecutar el comando anterior, abrirá un proxy SOCKS en mi **localhost:1080**. Después podría usar herramientas como ProxyChains que es una herramienta que permite encadenar múltiples proxies para anonimizar y redirigir tráfico de una aplicación a través de diferentes servidores, para emplear mis tools como Nmap, Metasploit o Gobuster y hacer parecer que el tráfico de estas herramientas proviene del servidor SSH.

Escaneos autenticados => ayudan a obtener una superficie de ataque más completa, necesita credenciales a nivel root ya que los comandos que ejecutará necesitan de privilegios elevados.

Escaneo de descubrimiento => su objetivo es identificar la superficie de ataque del objetivo, empezando por escanear puertos, luego revisa los servicios que corren en cada puerto y los compara con los datos de su base de datos.

Escaneos completos => esto es hacer un escaneo ejecutando cada opción de la herramienta y sus complementos/Plugins enfocado a un sistema o conjunto de sistemas similares, pero estando dispuesto a correr riesgos.

Escaneos furtivos => ideal para escanear sistemas que están en producción sin alertar al equipo de ciberdefensa.

Escaneos de cumplimiento => escaneos orientados al cumplimiento normativo.

Concepto clave => backporting => es una solución de un problema de seguridad, básicamente agarra un parche creado para una versión más nueva de un software y se lo aplica a la versión más vieja, la cual es utilizada. Esto permite que la versión más vieja siga siendo segura mientras se utiliza sin necesidad de tener que actualizar y traer problemas de compatibilidad.

ATAQUES DE INGENIERÍA SOCIAL:

El objetivo de esta fase es recopilar información y aprovecharse del eslabón más débil de una empresa, las personas, a través de la elicitación (es el acto de obtener conocimiento o información de las personas).

Interrogador => actor principal por el cual se obtendrá la información deseada del objetivo a través de preguntas; las mismas pueden ser abiertas (dejando que el objetivo se exprese lo más que pueda y de ahí recopilar lo esencial) o pueden ser cerradas (cuando el interrogador toma las riendas de la charla hacia un objetivo en concreto). Es importante que encuentre un equilibrio entre preguntar poco y pasarse.

Aspectos principales en los que debería prestar atención a la hora de interrogar:

- Postura o lenguaje corporal del objetivo.
- Color de piel o cara del objetivo como respuesta de las preguntas o charla.
- Dirección de la cabeza u ojos del objetivo al hablarnos.
- Movimiento de pies y manos al responder del objetivo.
- Expresión de boca y labios del objetivo.
- Tonos, velocidad y cambios de tonos de la voz del objetivo.
- La longitud de las palabras del objetivo como sus pausas.

Una forma de acercarse puede ser mediante la suplantación y pretexto, por ejemplo, hacerse pasar por un colaborador de la empresa con “x” rol dentro de la misma que requiere de algún dato o información sobre un tema en específico.

Situación de ejemplo => el interrogador se puede hacer pasar por un miembro IT, se acerca al objetivo con la excusa de preguntar (o inventar) si su sistema tiene algún problema con el fin de acceder a este y conectar una memoria externa cargada de scripts maliciosos.

Pharming => otra forma de engañar al objetivo es mediante una redirección DNS, básicamente suplantar un sitio web que frecuenta entrar el objetivo con el fin de obtener sus credenciales o información sensible, como también de incitarlo a que instale algún malware. Esto se consigue mediante DNS Spoofing.

DNS Spoofing => suplantar una dirección DNS legítima con el fin de obtener información valiosa, por ejemplo, suplantar la dirección IP de www.facebook.com con la del host atacante para que el objetivo introduzca la dirección original pero sea redirigido a un sitio fraudulento.

Situación de ejemplo II => Otra forma más elaborada de recaudar información sobre un objetivo es mediante una entrevista laboral falsa, se crea una oferta muy seductora para la persona objetivo relacionada sobre su área de especialización con el fin de concretar una reunión e interrogarla con preguntas sobre el tipo de dispositivos de red (routers, switches, firewalls, etc.) que hay en su empresa, ahondar sobre su configuración y sobre la metodología de trabajo. Debido a que en una entrevista la persona suele querer destacarse lo máximo posible, no sería un obstáculo para preguntas técnicas de este tipo y que brinden información sin requerir de un escaneo de red.

Phishing => un clásico ataque de ingeniería social basado en la suplantación de identidad, se suelen mandar por correo electrónico junto a un enlace para que la víctima se lo descargue y se infecte con algún malware, usualmente un ransomware.

Spear phishing => es un ataque de phishing focalizado en un grupo de personas o empresas, los atacantes analizan al objetivo de forma minuciosa para crear una trampa y recopilar información valiosa.

Whaling (caza de ballenas) => es un ataque a los “peces gordos” de una empresa con el objetivo de recopiar sus credenciales y pivotear en el alto nivel.

Vishing => es un phishing pero mediante llamadas o mensajes de voz, en lo cual un atacante se hace pasar por una determinada persona jerárquica para engañar al objetivo y sustraerle información valiosa.

Smishing => phishing por mensajería instantánea, se usa mayormente para que el objetivo descargue un malware y recopilar su información.

Abandono de USB => se deja una unidad USB tirada con el fin de que alguien la busque y la conecte en algún PC; dicha memoria trae una carga de malware que al conectarla al dispositivo, lo infectará.

Ataque de bebedero => el atacante estudia un sitio web que el objetivo frecuenta visitar con el fin de encontrar una vulnerabilidad que le permita inyectar código y así redirigirlo a un sitio web falso e incentivar a que descargue un malware o ingrese datos confidenciales.

Ataques Físicos

Piggybacking (acceso no autorizado por acompañamiento) => intrusión por engaño, usando a una persona con acceso a un área restringida para que haga entrar al atacante.

Tailgating (intrusión por seguimiento) => seguir a una persona con acceso a un área restringida sin que se dé cuenta y así lograr entrar al sector no autorizado.

Lo anterior es evitable con mantraps (vestíbulos de control de acceso) que requieran un PIN o tarjeta de acceso y otra puerta de estas más adelante que requieran de datos biométricos.

Dumpster diving (búsqueda en la basura) => cuando un atacante se mete en la basura del objetivo y trata de buscar archivos, papeles o algo que le brinde información sobre la víctima y que pueda ser usada para fuerza bruta de credenciales o ataques similares.

Shoulder surfing (vigilancia por encima del hombro) => puede ser de cerca o a la distancia, y como dice el nombre, se basa en leerle las credenciales o información confidencial al objetivo mirando lo que este introduce en un formulario o sitio.

Clonación de credenciales => mediante software o hardware específico para la clonación, el atacante puede replicar las credenciales y así obtener acceso a determinado recurso o área de una organización.

Tools para Ingeniería Social

SET => es una herramienta desarrollada por David Kennedy y se puede integrar con otras tools como BeEF y Metasploit. Ofrece plantillas y facilidades para realizar varios de los ataques de ingeniería social anteriormente vistos, Algunos de estos son: Phishing, Pharming, Unidad USB infectada, ataque de bebedero, generación de archivos infectados, etc.

Esta herramienta también permite realizar técnicas posteriores a la explotación como emplear Meterpreter o usar un archivo DLL para la ejecución de código remoto mediante una reverse shell.

BeEF => es un framework para la explotación de navegadores y entre las tantas cosas que puede realizar, permite la explotación de vulnerabilidades XSS para incentivar que el objetivo descargue malware. Algunos de los ataques que se podrían realizar son: obtención de cookies de sesión, envío de notificaciones falsas para invitarlos a descargar malware, etc.

El punto de vinculación entre ambas herramientas sería, entre infinidad de opciones, el de clonar una página real con SET y mediante BeEF (una vez de haberle comprometido el navegador al objetivo y realizarle DNS Spoofing) obtener sus credenciales o infectarlo con malware.

Tools para el Phishing Telefónico

SpoofApp => app para iOS y Android cuya utilidad es falsificar números telefónicos.

SpoofCard => disponible para iOS y Android, además de lo anterior permite la modificación de voz, sonidos de fondo y demás.

Asterisk => su utilidad principal es administrar llamadas VOIP, pero se puede usar para la falsificación de números.

Técnicas / métodos de influencia de la ingeniería social para obtener más información

Autoridad => demostrar autoridad organizativa, legal o social mediante la confianza al comunicarse.

Escasez y urgencia => crear una escena de escasez mediante una situación de urgencia.

Prueba social => influir en el objetivo demostrándole que otras personas (especialmente sus pares, colegas o un grupo grande) ya han realizado o aceptado la acción deseada. Se apela a la tendencia humana de seguir el comportamiento de la mayoría o de aquellos considerados 'normales' en un contexto dado, para validar una decisión.

Semejanza => espejar los gustos y afinidades (modo de vestir, hablar, etc. etc.) del objetivo con el fin de crear un ambiente a gusto y suscitar a que el objetivo divulgue la información deseada.

Miedo => inducir a una situación de estrés que derive a miedo a través de una escena que requiera prontitud de parte del objetivo. Mediante el miedo, se les obliga a pensar rápido y que tomen decisiones pésimas.

EXPLOTACIÓN DE REDES CABLEADAS E INALÁMBRICAS

El objetivo de esta fase es enumerar los activos informáticos del objetivo para lograr descubrir y explotar vulnerabilidades de redes y así obtener información valiosa de usuarios o dispositivos.

Una vez listados los activos y descubierto sus protocolos y servicios activos, se empezaría a diseñar las explotaciones para cada uno.

Tipos de explotaciones de Red

- Explotaciones basados en la resolución de nombres de Windows.
- Envenenamiento de caché DNS.
- Explotaciones SMB.
- Explotaciones SNMP.
- Explotaciones SMTP.
- Explotaciones FTP.
- Transferencia de Hash.
- Ataques de ruta (MITM)
- Eliminación de SSL.
- Ataques DoS y DDoS.
- Omisión del control de acceso a la red (NAC).
- Ataques de salto a la red de área local virtual (VLAN)

Resolución de nombres de Windows y ataques de SMB

Los tres principales protocolos de resolución de nombre de dominios son: NetBIOS, LLMNR y DNS.

NetBIOS => es usado en redes Windows para compartir archivos e impresoras, vulnerable a envenenamiento de caché y Relaying de credenciales (un atacante intercepta una solicitud de autenticación legítima de un usuario y la **retransmite (relay)** a otro servidor o servicio, haciéndose pasar por el usuario original).

En redes antiguas de Windows, NetBIOS actúa como el protocolo DNS a la hora de relacionar un dominio con una IP con la diferencia que NetBIOS lo hace para identificar archivos, impresoras y equipos de una red local con el fin de dejar preparado todo para cuando SMB lo requiera.

En pocas palabras, NetBIOS proporciona los nombres y ubicaciones, y SMB maneja la transferencia y el acceso a los recursos compartidos.

Las vulnerabilidades de NetBIOS se producen porque no verifica la autenticidad de las respuestas, haciendo que un atacante pueda interceptar el tráfico o las solicitudes para obtener los hashes NT Local Manager (NTLM) y realizar relaying. A esto se le suma que transporte los datos en texto plano.

NetBIOS ofrece tres servicios diferentes:

- **NetBIOS-NS (NetBIOS Name Service)** => registro y resolución de nombres.
- **NetBIOS-DGM (NetBIOS Datagram)** => comunicación sin conexión (sin Three-Way Handshake ya que usa UDP y no TCP).
- **NetBIOS-SSN (NetBIOS Session)** => comunicación con conexión (con Three-Way Handshake, usa TCP).

Puertos usados por NetBIOS para realizar operaciones:

- **Puerto TCP 135** => MS-RPC (Microsoft Remote Protocol Call) para comunicaciones cliente↔cliente | cliente↔servidor.
- **Puerto UDP 137** => NetBIOS-NS.
- **Puerto UDP 138** => NetBIOS-DGM.
- **Puerto TCP 139** => NetBIOS-SSN.
- **Puerto TCP 445** => SMB.

LLMNR => Link-Local Multicast Name Resolution, es un protocolo para la resolución de nombres en una LAN que hace de relevo cuando DNS no está disponible. Este protocolo es vulnerable a envenenamientos de respuesta y robo de credenciales.

Este protocolo no tiene una autenticación fuerte. Su funcionamiento es básico, cuando no hay un servidor DNS, les pregunta a los hosts de su red local la dirección IP de un nombre de dominio determinado.

Grupo de trabajo y Dominios

Grupo de trabajo => grupo de hosts donde cada uno tiene su propia configuración y es administrado por cada usuario.

Dominio de trabajo => funciona como un todo, centralizado en un servidor central; los usuarios solo usan su host para acceder y autenticarse en este. La configuración y todo lo demás está ya creada y administrada en el servidor central.

Aprovechamiento de vulnerabilidades en NetBIOS, SMB y LLMNR

NetBIOS => en sistemas Windows es común dejar el nombre por defecto de un grupo de trabajo como "WORKGROUP" y empezar a compartir recursos, usualmente también va de la mano el uso de credenciales débiles dejando en bandeja la posibilidad de enumerar las máquinas de ese grupo y hacer fuerza bruta contra las credenciales.

LLMNR => un ataque común es falsificar una fuente común LLMNR para la resolución de nombres de dominios, respondiendo al tráfico UDP 5355 de este protocolo y al tráfico del puerto UDP 137 de NBT-NS. Una vez hecho esto, si el host objetivo solicita un recurso que requiere que se autentique antes de acceder a este, al tener el servicio LLMNR envenenado, las credenciales (nombre de usuario) y la autenticación (hash NTLMv2) que use, serán redirigidas (Credential Relay) hacia mí, para posteriormente offline tratar de aplicarles fuerza bruta y descryptarlas. Las herramientas ideales para este tipo de ataques son: NBNSpoof, Metasploit, Responder y Pupy.

Explotaciones para SMB

Searchsploit => utilidad para la búsqueda de exploit para este protocolo.

Metasploit => framework que viene con exploits para la explotación de SMB, un ejemplo es la vulnerabilidad EternalBlue.

Envenenamiento de la caché de DNS

Este ataque consiste en inundar de datos falsos al servicio DNS para cambiar/manipular la caché DNS para que al ingresar a determinado sitio, en vez de ir al original, el objetivo se redirija al falso. Una forma de evitar esto es configurar los servidores DNS para que dependan lo mínimo de otros servidores DNS.

Servidores con BIND 9.5.0 => tienen funciones que evitan estos ataques de envenenamiento mediante la asignación aleatoria de puertos y el otorgamiento de ID a cada transacción DNS criptográficamente segura. Otra forma de protegerse es limitando las consultas DNS recursivas, almacenar datos relacionados con el dominio que se está solicitando y restringir las respuestas a las consultas con el fin de dar información solo del dominio solicitado.

DNSSEC (Domain Name System Security Extensions) => protege el sistema DNS mediante firmas digitales, esto protege los sistemas de envenenamientos DNS garantizando que las respuestas DNS sean auténticas y no hayan sido manipuladas.

Explotaciones de SNMP

SNMP => usa el puerto 161 y se usa para la administración de redes. Las dos versiones más populares de este protocolo son SNMPv2c y SNMPv3. La información de administración de guarda en una DB llamada "MIB" (Management Information Base). Un ataque común para este servicio sería enumerar los servicios que ofrece y luego tratar de hacer fuerza bruta a las contraseñas. Una implementación moderna sería usar NETCONF con routers y switches más modernos.

La dirección de los scripts de Nmap para realizar este ataque sería el siguiente:

/usr/share/nmap/scripts

snmp-check => tool para recopilar información de dispositivos que usen este protocolo.

Explotaciones de SMTP

El atacante podría usar servidores de correo electrónico mal configurados para realizar phishing o spam. Este protocolo es de servidor a servidor, a diferencia de POP3 o IMAP que es de cliente a servidor y viceversa.

Puertos TCP relacionados a servicios de correo electrónico:

- ***Puerto 25*** => puerto predeterminado SMTP.
- ***Puerto 465*** => SMTPS, la versión segura de SMTP que corre sobre SSL. Reemplazado por STARTTLS
- ***Puerto 587*** => puerto SSMTP para comunicaciones cifradas mediante STARTTLS. Los agentes de usuario de correo (MUA) de STARTTLS usan el puerto 587 para enviar correos pero también usan el 25.
- ***Puerto 110*** => puerto predeterminado y no cifrado usado para POP3
- ***Puerto 995*** => puerto predeterminado para POP3 en comunicaciones cifradas.
- ***Puerto 143*** => puerto predeterminado y no cifrado para IMAP.
- ***Puerto 993*** => puerto predeterminado y cifrado para IMAP.

Open Relay en SMTP

Si un servidor de correo electrónico tiene la retransmisión abierta, va a aceptar la transmisión de correos electrónicos de y hacia cualquier usuario. Esto es ideal para el phishing, spam y demás. Nmap tiene un script para aprovechar esta vulnerabilidad: ***smtp-open-relay.nse***

Comandos útiles para usar con estos servidores

- ***HELO*** => inicia conversación con el servidor, el comando se escribe: ***HELO 10.1.2.14***
- ***EHLO*** => inicia conversación con un servidor SMTP extendido (ESMTP). Este comando se usa de la misma manera que el comando HELO.
- ***STARTTLS*** => se usa para entablar una conexión segura con un servidor de correo electrónico usando TLS.
- ***RCPT*** => Se utiliza para indicar la dirección de correo electrónico del destinatario.
- ***DATA*** => se utiliza para iniciar la transferencia del contenido de un mensaje de

correo electrónico.

- **RSET** => se utiliza para restablecer (cancelar) una transacción de correo

electrónico.

- **MAIL** => Se utiliza para indicar la dirección de correo electrónico del remitente.
- **QUIT** => se utiliza para cerrar una conexión.
- **HELP** => se utiliza para mostrar un menú de ayuda (si está disponible).
- **AUTH** => se utiliza para autenticar un cliente en el servidor.
- **VRFY** => se usa para verificar si existe la casilla de correo de un usuario.
- **EXPN** => se utiliza para solicitar o expandir una lista de correo en el servidor

remoto.

Tool para evaluar un servidor SMTP

smtp-user-enum => recopilación y enumeración de información importante del servidor.

En un servidor, los comandos VRFY y EXPN deben ser deshabilitados.

Explotaciones de FTP

FTP heredado no usa cifrado ni valida la integridad. Se recomienda usar FTPS (FTP + SSL/TLS) y SFTP (SSH) con un algoritmo de cifrado fuerte como AES junto con algoritmos de hashing seguros para la validación de la integridad como SHA-2 o SHA-512. Los servidores FTP permiten la autenticación de usuarios anónimos, lo cual puede ayudar a que un atacante agregue archivos no autorizados al servidor para la exfiltración.

Situación de ejemplo => un atacante comprometió información confidencial de un objetivo, luego de haberlo hecho, la pasó al servidor FTP y de forma anónima ingresó a este y se bajó los datos sin que nadie supiera.

En casos de tener el acceso anónimo, se recomienda editar el archivo de configuración FTP para deshabilitar la opción. Para hallar el archivo, si por ejemplo uso vsFTPD, la ruta estará en **/etc/vsftpd.conf**.

Ataques de tipo Pass-the-Hash

Las contraseñas en Windows se almacenan en forma de hashes en un archivo llamado SAM (Security Account Manager). Esos hashes están creados bajo un algoritmo propio de Microsoft haciendo que las aplicaciones y el sistema operativo no sepan las contraseñas. Los servicios de Windows recurren a SAM para usar esos hashes en la autenticación del usuario.

↓ autenticación

NTLM => New Technology LAN Manager, es un conjunto de protocolos que usa Microsoft para la autenticación pero que desde el 2000 fue reemplazado por Kerberos; aunque hay situaciones en la que aún se usa este conjunto de protocolos, como por ejemplo si un cliente se autentica con una dirección IP en un servidor o si se autentica en un servidor de un bosque de Active Directory diferente donde no existe una confianza transitiva establecida con Kerberos, actuando NTLM como el protocolo de autenticación fallback. Otras situaciones podrían ser si un cliente se autentica en un servidor que no es de un dominio o si la conexión con Kerberos está bloqueada por un firewall.

↓ vulnerabilidad de hashes

Una vez aclarado lo anterior, un ataque de transferencia de hashes es cuando un atacante obtiene los hashes de contraseñas de un objetivo, y como no se pueden revertir, los usa para autenticarse en diferentes servicios.

↓ proceso que evita el atacante

LsaLogonUser => API que convierte las contraseñas de inicio de sesión de Windows en hashes. Un ataque Pass The Hash se saltea esto y manda el hash directamente al servicio ya que cuenta con el hash del objetivo.

Mimikatz => tool para dumper hashes de la RAM. Incluida en Meterpreter para la post explotación.

Ataques basados en Kerberos y LDAP

Como se mencionó antes, Kerberos es un protocolo de autenticación de Windows. Kerberos tiene tres elementos: cliente, servidor y KDC (Key Distribution Center) => este incluye el servidor de autenticación y el servidor que otorga tickets para acceder a servicios.

Pasos de la autenticación en Kerberos

Paso 1 => el usuario se autentica en el Servidor de Autenticación (AS => que forma parte del servidor => KDC).

Paso 2 => el Servidor de Autenticación de sesión (AS, Authentication Server) chequea que el usuario esté permitido para ingresar y en caso de estarlo, le da un Ticket Granting Ticket para que ingrese al dominio y solicite los tickets de servicios que desee.

Paso 3 => luego, si el usuario quiere solicitar acceso al “Servidor 2”, se dirige al servidor Tickets Granting Server (TGS => forma parte también del servidor => KDC), solicita acceso al “Servidor 2” y si el servidor Ticket Granting Server corrobora que el usuario tiene autorización para acceder a los servicios del “Servidor 2”, le otorga un ticket de servicio.

Paso 4 => el usuario con ese ticket se dirige al “Servidor 2” y se lo da para acceder a sus servicios, el “Servidor 2” toma ese ticket, y si lo valida, le brinda el servicio al usuario.

LDAP => Protocolo Ligero de Acceso a Directorios, es usado por Active Directory para el acceso ya que admite autenticación por Kerberos.



LDAP usa la estructura jerárquica de árbol invertido (DIT, Directory Information Tree)



En LDAP cada entrada tiene una posición definida.



DN (Distinguished Name) representa la ruta completa de la entrada, o sea, muestra la posición definida.

Ataque Golden Ticket

Este ataque se da cuando un atacante compromete un sistema que pertenece a un dominio de Active Directory y logra obtener el hash NTLM (o las claves AES) de la cuenta de servicio Kerberos TGT (KRBGT), luego con esto genera un ticket con privilegios de cualquier tipo a lo que se conoce como “ticket de oro” perteneciente a un usuario existente o no.

1 - El atacante compromete un sistema que forma parte de un dominio AD.

2 - Luego desde esa cuenta, obtiene los hashes de la cuenta Kerberos TGT.

3 - Con esos hashes, obtiene el "ticket de oro" ya que puede generar tickets de cualquier tipo que pueden pertenecer o no a un usuario existente.

Empire => tool que sirve para obtener tickets de oro y realizar otros tipos de ataques. Es un framework para post explotación que trae un agente de Windows puro de PowerShell y otro de Python.

Ataque Silver Ticket

Se logra cuando un atacante falsifica directamente un Ticket de Servicio para un servicio específico en un servidor específico, sin necesidad de interactuar o pasar por la validación del TGS (Ticket Granting Server), o sea, se bypassa el TGS.

↓ *Los servicios importantes para este ataque son*

CIFS => (Commons Internet Files Services) de Windows permite que accedamos a los recursos compartidos de un servidor en particular.

HOST => es un Nombre Principal de Servicio (SPN) genérico para varios servicios ejecutándose en un host como el proceso **schtasks.exe** de tareas programadas, WMI (Windows Management Instrumentation) o el acceso remoto vía RPC/DCOM en un servidor.

↓ *¿Por qué son importantes?*

Para la creación de un Silver Ticket, el atacante requiere:

- El hash **NTLM** (o las claves AES) de la cuenta del servicio objetivo. Para servicios como CIFS o HOST en un servidor, la cuenta del sistema suele ser la que termina con el símbolo \$, por ejemplo: SERVER01\$
- El **SID** (Security Identifier) del dominio y su nombre completo.
- El **SPN** (Service Principal Name) del servicio objetivo, por ejemplo:
cifs/servidor.dominio.com o **host/servidor.dominio.com**

↓ *Uso de tools para la obtención de esta información*

Se puede usar Empire para obtener y filtrar la información importante de un dumpeo realizado previamente por Mimikatz de la memoria RAM de un sistema comprometido.

Delegación de Kerberos

La delegación de kerberos sin restricciones es una función que permite la reutilización de las credenciales de un usuario final para acceder a los recursos de un servidor diferente. Esto solo debe estar permitido en servidores de confianza pero esto no lo aleja de ser aprovechado de forma abusiva y es por ello que no está habilitado de forma predeterminada en Active Directory y no se recomienda hacerlo.

Kerberoasting

Kerberoasting es un ataque de post explotación en Active Directory donde un atacante se hace pasar por un usuario común y solicita tickets de autenticación al DC donde reside el KDC y su componente principal, el TGS para cuentas de servicio y extrae sus hashes de contraseña.

Luego, descifra esos hashes fuera de línea, sin necesidad de enviar paquetes a la víctima ni tener credenciales de administrador.

Si la contraseña es débil, el atacante puede obtener acceso al servicio comprometido. Se aprovecha de contraseñas débiles en las cuentas de servicio, que resultan en claves de cifrado vulnerables para los tickets, derivado de malas prácticas de contraseñas, por lo que cambiar regularmente las credenciales de servicio es ideal para prevenirlo.

Ataques en Ruta (MITM)

Básicamente este ataque se da cuando un atacante se pone en el medio de la comunicación entre un objetivo y el dispositivo de destino con el fin de interceptar la comunicación y tratar de recopilar información sensible o manipular la información en tránsito. Este ataque puede ocurrir en la capa 2 (enlace de datos) o en la capa 3 (red).

Suplantación ARP y envenenamiento de caché ARP

Envenenamiento de caché => También conocido como “Suplantación ARP”, este ataque desemboca en un ataque en ruta (MITM). Puede apuntar a un host, un router o un switch; el objetivo es envenenar la caché de los sistemas conectados a la red en la que está el objetivo para que en vez de mandar el tráfico al destino original, se lo manden al atacante ya que este envenenamiento de caché cambia las direcciones originales.

Recomendación => usar DAI (Dynamic ARP Inspection) en los switches ya que estos ataques son en capa 2.

↓ Otros tipos de ataques

Suplantación MAC => la idea de este ataque es suplantar la MAC de un dispositivo de una red (idealmente un router) con el fin de eludir las medidas de control de acceso o hacer un ataque en ruta (MITM).

Ataque usando STP => este ataque de capa 2 consiste en poner un switch en una red y manipular el protocolo Spanning Tree Protocol para convertirlo en un switch raíz (root).

Ataque MITM de capa 3 => consiste en colocar un router dudoso en una red y engañar a los otros router para que crean que el dudoso tiene las mejores rutas.

Ataque MITM con malware => a través de la infección de un sistema objetivo para capturar paquetes antes que sean enviados y cifrados.

↓ **Tool para esto**

SSLStrip => observa el tráfico HTTPS, lo captura y lo devuelve al atacante mediante un enlace no cifrado usando HTTP.

Ataques de degradación

Este ataque hace que el sistema elija el algoritmo de hashing o cifrado más débil posible. Un ejemplo de este ataque fue la vulnerabilidad de relleno de Oracle en cifrado heredado llamada POODLE en OpenSSL, este ataque permitía que un cliente fuera forzado a negociar el uso del protocolo SSL 3.0 (una versión anterior e insegura de SSL/TLS), exponiendo la comunicación. Este tipo de vulnerabilidades se da en sistemas con versiones antiguas de softwares.

Ataques de manipulación de rutas

El más conocido es el ataque de secuestro de BGP (Border Gateway Protocol). Es un protocolo de enrutamiento dinámico para enrutar el tráfico de internet. Para realizar este ataque, hay que comprometer o configurar un enrutador de perímetro para anunciar prefijos que no pertenecen legítimamente ni se han anunciado a su organización.

Si el anuncio malicioso contiene una ruta más específica que el anuncio legítimo o presenta una ruta más corta, el tráfico de la víctima podría redirigirse al atacante.

Ataques DoS y DDoS

Se dividen en las siguientes categorías:

- **Ataques DoS directos** => los paquetes del ataque vienen de un solo origen, suelen ser paquetes TCP SYN y su objetivo es abrumar al objetivo con una cantidad monstruosa de paquetes. Otra forma de referirse a este ataque es como “ataque de inundación SYN”. Este tipo de ataques llevados a cabo en entornos cloud es para que el objetivo pague más por el uso y los recursos que usa.

↓ **ataque relacionado**

Desbordamiento de búfer => provoca el bloqueo de un servidor o dispositivo de infraestructura que lleva a una condición de DoS.

- **Botnet (DDoS)** => redes de bots que llevan a cabo, entre tantas cosas, ataques DDoS. Las botnets son un conjunto de dispositivos comprometidos (zombificados) que un atacante controla desde un servidor de comando y control (CnC).

- **Ataques DoS y DDoS reflejados** => se da cuando un atacante falsifica el origen de las consultas y la fuente que va a responder a esas consultas se vuelva, de forma involuntaria, partícipe del ataque reflejado porque manda ese tráfico al objetivo que fue suplantado para las consultas. Para estos ataques se suele usar UDP por la falta del Three-Way Handshake.

Ejemplo: un atacante manda solicitudes al servidor NTP (Network Time Protocol) con una IP suplantada y ese servidor va a responderle pero al objetivo y no al atacante.

- **Ataques DDoS de amplificación** => es otro estilo de DoS reflejado en los que el atacante (con la dirección IP de origen falsificada) manda paquetes de un tamaño menor a una fuente y esta, en su respuesta, manda paquetes mucho más grandes inundando al objetivo.

Ejemplo => un atacante falsifica su IP y manda consultas a un servidor DNS abierto (como el de Google: 8.8.8.8), y el servidor manda paquetes de respuestas a esas consultas mucho más grandes.

Omisión del control de acceso a la red (NAC)

NAC es una tecnología que interroga a los dispositivos antes de unirse a una red cableada o inalámbrica y se usa junto a 802.1X para la gestión y el cumplimiento de identidades.

El NAC se configura en un AP o switch de acceso para que revise al dispositivo que quiere unirse a la red si cumple con la política de seguridad establecida en la red, como que el dispositivo cuente con un antivirus, un firewall, un antimalware o una versión determinada de un SO antes de unirse a la red.

Las NAC pueden permitir que nodos específicos como impresoras, teléfonos VoIP y otros dispositivos puedan unirse a la red mediante una lista de permitidos (lista blanca) de direcciones MAC. Los niveles de acceso pueden ser configurados por el administrador de red pero llevaría a que sea difícil de mantener una política de red dinámica.

El problema de esto es que un atacante podría falsificar la MAC de un dispositivo que esté en la lista blanca para omitir la configuración NAC.

Salto de VLAN (VLAN Hopping)

Para permitir la comunicación de dispositivos que pertenecen a diferentes VLANs a través de un mismo enlace físico (por ejemplo, entre switches o con un router), se utilizan puertos troncales. Dichos puertos transportan el tráfico de múltiples VLANs y aplican etiquetas a cada trama para identificar a qué VLAN pertenece.

El etiquetado utilizado para las tramas troncales se basa en el protocolo 802.1Q. La información más relevante que contienen estas etiquetas es la ID (Identificador) de

cada VLAN, la cual permite a los switches reenviar las tramas correctamente dentro de su segmento de red virtual.

↓ *explicación del ataque*

El salto de red de área local virtual (VLAN) => este ataque tiene como fin obtener el acceso al tráfico de otras VLANs al que no estaría permitido. Los dos métodos principales para realizar este ataque son la suplantación de conmutador y etiquetado doble.

- Suplantación de conmutador (switch): Se realiza haciéndose pasar por un switch de enlace troncal, lo que implica negociar exitosamente un enlace troncal mediante el envío de los protocolos de enlace troncal específicos. Una vez establecido el troncal, el atacante puede enviar tramas con la etiqueta de cualquier VLAN, obteniendo acceso a su tráfico.

Por ello, y para evitar esto, no es recomendable usar la VLAN 1 ya que es la predeterminada. En un switch nuevo, se recomienda apagar todos los puertos y asignarlos a una VLAN que no se use más que como "punto muerto" (blackhole VLAN). A medida que se vayan creando las VLAN, se tienen que ir abriendo los puertos y asignándose a las VLANs correspondientes, configurándolos como puertos de acceso (access ports) a menos que se requiera explícitamente un troncal.

Hay que recordar que este ataque crea enlaces troncales con las etiquetas deseadas que apunten a una subred deseada.

- Etiquetado doble: Este ataque aprovecha una característica de la mayoría de los switches configurados con 802.1Q, y es que suelen procesar y eliminar solo la etiqueta más externa de una trama.

El atacante construye una trama especial que contiene dos etiquetas de VLAN:

- a) Una etiqueta externa (o falsa) que coincide con la VLAN nativa del enlace troncal al que está conectado el atacante.
- b) Una etiqueta interna (u oculta) que corresponde a la VLAN objetivo a la que el atacante desea acceder.

Cuando esta trama llega al primer switch, el switch procesa y elimina la etiqueta externa (ya que coincide con su VLAN nativa). Como el tráfico de la VLAN nativa generalmente no se etiqueta al salir por un troncal, la trama (que ahora solo contiene la etiqueta interna) se reenvía sin una nueva etiqueta externa hacia el enlace troncal.

De esta manera, la trama viaja por el enlace troncal al siguiente switch de la red. Este segundo switch (o cualquier switch subsiguiente en la ruta) verá y procesará la etiqueta interna (la de la VLAN objetivo), reenviando la trama al destino dentro de esa VLAN a la que el atacante originalmente no tenía acceso.

Ataques de inanición de DHCP y servidores DHCP no autorizados

Los ataques más famosos son:

- Inanición de DHCP: un atacante difunde una gran cantidad de mensajes DHCPDISCOVER/REQUEST al servidor DHCP con MAC de origen falsa, para que al responder el servidor, las direcciones disponibles en el servidor DHCP se agoten y de esta forma el atacante da lugar a otro ataque.

↓

- Suplantación de DHCP: este ataque se relaciona con el anterior ya que un atacante configura un servidor DHCP para que responda a las solicitudes verdaderas de los clientes de esa red y otorgarles una configuración para así posteriormente interceptarles la comunicación.

↓

Yersenia => tool para crear un servidor DHCP dudoso.

Aprovechamiento de las vulnerabilidades inalámbricas

Puntos de acceso no autorizados

Es un ataque bastante simple y consiste en que un atacante instale un AP no autorizado y engañe al objetivo para que se conecte a él. El objetivo es interceptar el tráfico del objetivo, realizar ataques de tipo 'Man-in-the-Middle' (MITM) o incluso inyectar software malicioso en sus dispositivos.

Ataques de gemelos malvados (Evil Twin Attack)

Este ataque es igual al anterior con la diferencia en que copia exactamente la misma información del AP original pero le agrega un detalle como un anuncio de velocidad más rápida para engañar al objetivo. Cuando el objetivo accede a este gemelo malvado, pueden ser víctimas también de un envenenamiento DNS de alguna página web para que el usuario coloque sus credenciales allí y así el atacante logre obtenerlas.

Ataques de disociación (o desautenticación)

Este ataque consiste en hacer desautenticar al usuario legítimo del AP o router inalámbrico para así realizarle un ataque DoS o hacer que esos usuarios caigan en un gemelo malvado.

Airmon-ng => es una herramienta para escuchar y capturar SSID y tráfico inalámbrico.

Airodump-ng => herramienta para analizar y capturar tráfico inalámbrico.

Aunque un objetivo desactive la difusión SSID de su AP inalámbrico o router inalámbrico ni tampoco responda a sondeos de SSID, si se espía a la red el tiempo

necesario en algún momento se verá a un cliente asociándose a ese AP y de esa forma se podría obtener el SSID.

Aireplay-ng => es una herramienta para llevar a cabo la desautenticación

Ataques a la lista de redes preferidas

Los sistemas operativos y los clientes a veces tienen una lista de redes inalámbricas confiables/preferidas. A esto se lo denomina PNL (Preferred Network List), la cual incluye la SSID y las credenciales de conexión (como la clave pre-compartida o datos para autenticación empresarial) que corresponden a los protocolos de seguridad como WEP/WPA2/WPA3. Los clientes usan estas listas para asociarse automáticamente si no están conectados a un AP o router inalámbrico.

Los atacantes podrían hacerse pasar por redes inalámbricas y escuchar las solicitudes de los clientes para que estos se conecten a los dispositivos de los atacantes y escuchar o manipular la comunicación.

Interferencia y bloqueo de la señal inalámbrica

El objetivo de esto es crear una condición DoS total o parcial sobre una red inalámbrica, para lograr esto un atacante suele generar ruido aleatorio con las frecuencias que utilizan las señales inalámbricas.

Para esto es necesario adaptadores inalámbricos que inyecten paquetes y así desconectar a los clientes legítimos.

Conducción de guerra

Es una forma que tienen los atacantes de encontrar puntos de acceso inalámbricos desde donde sea que estén, o sea, con solo conducir (caminar) el atacante podría recopilar mucha información en poco tiempo.

Vuelo de guerra => es un ataque similar, donde un atacante desde un vehículo aéreo como un dron o un vehículo aéreo no tripulado y con una laptop o dispositivo móvil, buscará redes inalámbricas.

WiGLE => sitio web para ver y cargar información sobre una red inalámbrica.

Ataques por vector de inicialización (IV) y protocolos inalámbricos no seguros

El objetivo es obtener mucha información sobre el texto sin formato de un solo paquete y generar otra clave de cifrado que luego se puede usar para descifrar otros paquetes con el mismo IV; WEP es susceptible a este ataque. Y por ello se considera un protocolo obsoleto.

Ataques contra WEP => WEP es un protocolo inalámbrico obsoleto y extremadamente vulnerable. Su principal debilidad reside en el uso de un IV (vector de inicialización) de 24 bits enviado en texto claro y cómo lo emplea junto a RC4. Esto permite a un atacante, al recopilar suficientes paquetes (proceso acelerable con inyección de ARP), descifrar la clave pre-compartida (PSK) de la red y obtener acceso. Herramientas como Aircrack-ng son las usadas para este tipo de ataque.

Ataques contra WPA => WPA y WPA2 son protocolos con vulnerabilidades, siendo WPA3 la versión recomendada por su mayor seguridad. A diferencia de WEP, WPA no es susceptible a los ataques de IV. Sin embargo, un método de ataque común es capturar el "handshake de cuatro vías" entre un cliente y el AP, para luego intentar descifrar la clave pre-compartida (PSK) mediante un ataque de fuerza bruta.

Ataques de KRACK => significa "ataque de reinstalación de claves", es un tipo de vulnerabilidad que permite a atacantes no autenticados forzar la reinstalación de una clave de cifrado o integridad previamente usada en un dispositivo (cliente o AP), dependiendo de la configuración. Una vez reinstalada la clave, el atacante puede capturar e intentar descifrar el tráfico, o incluso falsificar/reproducir datos, manipulando las retransmisiones del protocolo de enlace.

Vulnerabilidades de WPA3 => WPA3 introdujo el "protocolo de enlace libélula" que utiliza el Protocolo de Autenticación Extensible (EAP). A pesar de ser más robusto, WPA3 presenta vulnerabilidades que pueden permitir a un atacante realizar ataques de canal lateral, ataques de degradación y condiciones de denegación de servicio (DoS).



FragAttacks es otro tipo de vulnerabilidad de WPA3.

Ataques de PIN de configuración protegida Wi-Fi (WPS) => WPS es un protocolo diseñado para simplificar la configuración de redes inalámbricas mediante un PIN. No obstante, la mayoría de sus implementaciones carecen de protección contra intentos fallidos, lo que las hace altamente vulnerables a ataques de fuerza bruta sobre el PIN. Herramientas como Reaver simplifican enormemente la ejecución de estos ataques para obtener la clave pre-compartida (PSK) de WPA.

Ataques de KARMA

Significa "Kicking Ass Radio Machines Automatically" o "karma ataca a las máquinas de radio automáticamente", es un ataque de tipo "Man-in-the-Middle" (MITM) que implica la creación de un Punto de Acceso (AP) falso. En este ataque, el atacante escucha las solicitudes de sondeo de los dispositivos inalámbricos (como celulares o laptops) y genera el mismo SSID que el dispositivo está buscando. Esto engaña al cliente para que se conecte automáticamente al AP del atacante, permitiendo la

intercepción del tráfico. Este método es muy efectivo para explotar la PNL (Preferred Network List) de los dispositivos.

Ataques de fragmentación

Estos ataques se dirigen a dispositivos configurados con WEP y tienen como objetivo adquirir 1500 bytes del algoritmo de generación pseudoaleatoria (PRGA), sin recuperar directamente la clave WEP. Una vez obtenido el PRGA, se utilizan herramientas como Packetforge-ng (del conjunto Aircrack-ng) para generar e inyectar paquetes inalámbricos, lo que facilita la ejecución de otros ataques de inyección.

Recopilación de credenciales

Este ataque busca obtener o comprometer credenciales de usuario. Se ejecuta frecuentemente mediante técnicas de ingeniería social (como el phishing), incluyendo la suplantación de APs inalámbricos o portales cautivos para engañar a las víctimas. Herramientas como Ettercap (para falsificar respuestas DNS y redirigir a sitios maliciosos) y el Social Engineering Toolkit (SET) son utilizadas para facilitar estos ataques.

Bluejacking y Bluesnarfing

Bluejacking => es un ataque que se realiza vía Bluetooth, dirigido a dispositivos vulnerables dentro del alcance. Consiste en que un atacante envía mensajes no solicitados a la víctima, a menudo utilizando una tarjeta de contacto (vCard) con un mensaje en el campo del nombre, a través del protocolo OBEX. Es considerado principalmente una forma de "spam" mediante conexiones Bluetooth.

Bluesnarfing => es un ataque Bluetooth que permite a un atacante obtener acceso no autorizado y robar información sensible de un dispositivo (como calendarios, contactos, mensajes, imágenes o el IMEI). Es más riesgoso que Bluejacking, ya que no solo transmite datos al dispositivo, sino que los extrae. Además, puede ser utilizado para desviar llamadas y mensajes entrantes de la víctima sin su conocimiento.

Ataques de Bluetooth de baja energía (BLE)

Las comunicaciones de Bluetooth de baja energía (BLE), muy utilizadas en dispositivos IoT, son susceptibles a ataques de tipo "Man-in-the-Middle" (MITM), donde un atacante podría modificar los mensajes. Los ataques de Denegación de Servicio (DoS) también son un problema para las implementaciones de BLE. Investigaciones, como las de la Universidad Estatal de Ohio, han revelado ataques de "fingerprinting" que exponen fallos de diseño y configuraciones incorrectas en dispositivos BLE.

Ataques de identificación por radiofrecuencia (RFID)

RFID es una tecnología que utiliza campos electromagnéticos para identificar y rastrear etiquetas (activas o pasivas) en inventarios, identificaciones, etc. Los ataques comunes contra dispositivos RFID incluyen el robo silencioso de información con lectores cercanos (Proxmark3), la clonación de etiquetas para obtener acceso físico, la implantación de skimmers detrás de los lectores, y ataques de amplificación NFC para exfiltrar datos sensibles a distancias mayores usando antenas amplificadas.

Difusión de contraseñas

Difusión de contraseñas => Es un ataque de fuerza bruta donde un atacante intenta una o pocas contraseñas comunes contra una gran lista de nombres de usuario. Esto busca evitar el bloqueo de cuentas al no realizar múltiples intentos en una sola cuenta.

↓

Relleno de credenciales => Un ataque similar que consiste en la inyección automatizada de pares de nombre de usuario y contraseña previamente expuestos en otras filtraciones de datos, asumiendo que los usuarios reutilizan sus credenciales en diferentes servicios.

Encadenamiento de explotaciones

Esta técnica implica que un atacante utilice múltiples vulnerabilidades (conocidas o de día cero) en secuencia. El objetivo es comprometer sistemas de manera más sofisticada, permitiendo robar, modificar o corromper datos al combinar los efectos de varias explotaciones.

EXPLOTANDO VULNERABILIDADES BASADAS EN APLICACIONES

Esta sección tiene como fin, recopilar los ataques más conocidos de entornos web. Recordar que una “transacción” es cuando se establece una comunicación entre un cliente web y un servidor web.

Estructura HTTP

Comunicación:

Host → (conexión TCP) → Servidor

Host → (request) → Servidor

Host ← (response) ← Servidor

Métodos HTTP:

- **GET** => Tomar algo del servidor.
- **HEAD** => Lo mismo que GET pero devuelve el encabezado HTTP sin el cuerpo del documento.
- **POST** => Poster/mandar algo al servidor HTTP desde un formulario por ejemplo.
- **TRACE** => Traza la ruta loopback a lo largo del recorrido hasta el servidor HTTP.
- **PUT** => Poner un recurso en el servidor HTTP.
- **DELETE** => Borra un recurso del servidor HTTP.
- **OPTIONS** => Muestra los métodos HTTP que acepta el servidor.
- **CONNECT** => Convierte la conexión de solicitud en un túnel TCP/IP.

URI y campo de ruta al recurso: Muestra la parte de la ruta solicitada por URL.

Número de versión de la solicitud: Versión HTTP usada por el cliente.

User-agent: Cliente web usado.

Código de estado de las respuestas HTTP:

- **Rango 100** => Informativos.
- **Rango 200** => Transacción exitosa.
- **Rango 300** => Redirecciones.
- **Rango 400** => Errores relacionados con el cliente.
- **Rango 500** => Errores relacionados con el servidor.

Estructura de URL HTTP

URL de ejemplo: <https://theartofhacking.org:8123/dir/test?id=89?name=omar&x=true>

- **Esquema (x://)** => Define el protocolo que irá antes de las // y los dos puntos.
- **Host** => Dirección IP o DNS del servidor web al que se quiere acceder.
- **Port** => Parámetro opcional para especificar el puerto por el cual escucha el servidor al que nos queremos conectar.
- **Ruta (Path)** => Ruta del directorio raíz hasta el recurso solicitado (por ejemplo desde '/' en Linux hasta un archivo en específico).
- **Path-segment-params** => Pares de nombre-valor (ej: id=89).

- **Query string** => Parte clave-valor opcional que representan los parámetros dinámicos de la solicitud. Suele estar precedido del signo '?' y usan '&' para unir pares clave-valor en la consulta.

API RESTful y SOAP

API RESTful => Interfaz de programación que ayuda a integrar un software con una aplicación web, usa JSON para la comunicación.

SOAP => Tecnología anterior a API REST que usa XML en vez de JSON.

CURL

Se usa para transferir datos desde una CLI o un Script. Dicha herramienta es Open Source y fue creada en 1998.

Ejemplos de uso:

curl <https://www.ejemplo.com> => pedir un sitio web mediante GET. Desde la CLI mostrará el HTML

curl -I <https://www.ejemplo.com> => lo mismo que el anterior pero solo mostraría las cabeceras HTTP. También se puede usar --head.

curl -O https://www.ejemplo.com/archivo_para_descargar.zip => para descargar un archivo desde la web y lo guarde con el mismo nombre que tiene en el servidor.

curl -X POST -d "nombre=Fabi&clave=MiSuperClave" <https://api.ejemplo.com/login>
=> para hacer un post en una página web. Muy útil para simular inicios de sesión, enviar datos a formularios para probar inyecciones (SQL, XSS), o interactuar con APIs vulnerables.

curl -L <http://sitio-con-redireccion.com> => para evitar redirecciones y ver el contenido original de la página. Es especialmente útil cuando las aplicaciones web usan redirecciones después de autenticación o para proteger recursos.

curl -A "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/100.0.4896.75 Safari/537.36"

<https://www.ejemplo.com/pagina-especifica> => especificar un user-agent, útil para hacer pasar que estoy usando otro navegador. Muy útil para evadir filtros básicos de User-Agent, simular ser un bot de búsqueda, o acceder a contenidos que solo se muestran a ciertos navegadores o dispositivos.

curl -o pagina_ejemplo.html <https://www.ejemplo.com> => para guardarme el código fuente de una página web y analizarlo localmente, guardar respuestas de APIs, o capturar la salida de herramientas o scripts remotos.

Tipos de ID de Sesión

- **PHPSESSID** => PHP
- **JSESSIONID** => J2EE
- **CFID/CFTOKEN** => ColdFusion
- **ASP.NET_SessionId** => ASP.NET

El ID de sesión puede indicar el marco y lenguaje de programación usa la aplicación web. Es por ello que se recomienda cambiar el nombre de la ID de sesión a uno genérico, la misma también debe de ser de al menos 128 bits para evitar ataques de fuerza bruta.

Cookies

Cookies no persistentes => son las de sesión, las aplicaciones modernas las usan para darles seguimiento a los usuarios durante una sesión después de la autenticación y cuando se cierra el navegador, la información de sesión expira. Por esto último es importante usar este tipo de cookies, para que la ID de la sesión no permanezca mucho tiempo en el disco.

Cookies persistentes => si tienen el atributo Max-Age (priorizado por clientes y aplicaciones web) o Expires y se almacena en disco hasta el vencimiento.

Fallas de la Lógica Empresarial

Básicamente es usar un flujo legítimo para realizar algo ilegítimo para lo que empresarialmente no fue pensado. Es difícil de poder detectar ya que no hay tool que ayude, pero para reducir las probabilidades de que ocurra, la validación de datos y el uso de un modelo de amenazas detallado ayudan.

Vulnerabilidades basadas en inyección

Las más conocidas son:

- **Vulnerabilidades de inyección SQL** => un atacante puede leer, modificar o eliminar datos en una base de datos al explotar esta vulnerabilidad. Esto se hace mediante consultas SQL maliciosas en los campos de entrada de una aplicación.

SELECT * FROM Customers WHERE ContactName LIKE '%Saavedra%'

SELECT * FROM Customers WHERE ContactName LIKE => Esta consulta es un ejemplo de lo que hace una aplicación web cuando se interactúa con un formulario o campo para introducir datos, la consulta se hace en segundo plano.

'%Saavedra%' => puede ser la entrada de un formulario web.

SQL Booleana => mario' OR 1=1 => este es un ejemplo básico de inyección SQL.

Categorías de inyección SQL

- SQL en banda: la información obtenida se muestra en el mismo lugar por el cual se hizo el ataque.
- SQL fuera de banda: pasa la información a otro sitio como por ejemplo al servidor del atacante.
- SQL ciega: este ataque no muestra ni transfiere nada, solo sirve para que el atacante recopile datos mediante el uso de consultas y la reacción del sitio.

Mitigaciones para la Inyección SQL

- Validación de entradas.
- Consultas estáticas.
- Consultas parametrizadas.
- Procedimientos almacenados si es que no generan SQL dinámico.

• ***Vulnerabilidades de Inyección HTML***

• ***Vulnerabilidades de inyección de comandos*** => cuando un atacante ejecuta comandos que no se pueden ejecutar en un sistema a través de una aplicación vulnerable. Estos ataques se dan cuando no se validan los datos proporcionados por el usuario en formularios web, cookies, encabezados HTTP y demás. El sistema vulnerable pasa los datos introducidos en esos campos a la shell del sistema. Actualmente este ataque no es tan frecuente. Los comandos se van a ejecutar con los permisos que tenga la aplicación vulnerable en el sistema.

• ***Vulnerabilidades de inyección de LDAP*** => este ataque se da por tener una validación de entrada mal configurada haciendo que se pueda ejecutar código en un servidor LDAP. Estos ataques podrían hacer que el atacante modifique el árbol de LDAP y la información crítica del negocio.

Los dos tipos de ataques LDAP:

- Omisión de autenticación: para omitir la verificación de usuario y contraseña.
- Divulgación de información: para enumerar recursos en un directorio de una organización y realizar reconocimiento.

Vulnerabilidades Basadas en la Autenticación

Las formas más comunes son:

- Fuerza bruta a credenciales.
- Secuestro de sesión.
- Redirigiendo al objetivo.
- Explotación de credenciales predeterminadas.
- Explotación de credenciales débiles.
- Explotación de Kerberos.

Secuestro de sesión => el método para el intercambio de ID en una sesión web son las cookies, la mecánica de las mismas funciona así:

- 1 – Se establece la conexión TCP.
- 2 – El usuario se loguea con el usuario y contraseña.
- 3 – El servicio web le retorna al cliente web las cookies de sesión.
- 4 – Las próximas solicitudes al servicio web se autenticarán mediante las cookies.
- 5 – El servicio web le responde al cliente con el contenido solicitado.

Lo anterior se debe dar mediante un canal cifrado como HTTPS.

El secuestro de sesión se da cuando se comprometen las cookies del objetivo, las formas de hacerlo son:

Predicción de tokens de sesión: al utilizar un marco de generación de ID débil y no recomendado.

Detección de sesiones: cuando se recopile paquetes de sesión en canales sin cifrar.

Ataque en ruta: cuando el atacante le intercepta el tráfico al objetivo y le recopila las cookies.

Ataques de Redireccionamiento

Este ataque se da cuando un servidor web acepta entradas no confiables haciendo que el servicio web redirija la solicitud a otra URL para que el objetivo instale malware u obtener sus credenciales.

Credenciales Predeterminadas

Este ataque se da cuando se explotan las credenciales predeterminadas en routers, switches, AP y otros dispositivos.

Vulnerabilidades de Kerberos

El ataque principal de Kerberos es el Golden Ticket, el atacante solo requiere comprometer un usuario local y obtener los hashes de contraseña de un sistema. Si ese sistema pertenece a un dominio, el atacante puede identificar un hash de contraseña del ticket de concesión de tickets kerberos (KRBtgt) para obtener el ticket de oro.

Otra vulnerabilidad es la delegación no restringida de Kerberos la cual permite que se use la misma credencial de usuario para acceder a otro servidor.

Vulnerabilidades de autorización

Contaminación de Parámetros

Se da cuando múltiples parámetros HTTP tienen el mismo nombre haciendo que la aplicación interprete los valores de forma incorrecta. A esto se lo conoce como HPP o HTTP Parameter Pollution.

Este ataque se puede hacer desde el lado del servidor como del cliente. Se realiza en campos para la introducción de datos como formularios.

Ej: URL => <https://store.h4cker.org/?search=cars>

'search' es la cadena de consulta y 'cars' el valor del parámetro, este último puede estar oculto entre otros parámetros; un atacante podría dejar este parámetro como está y agregarle otro:

<https://store.h4cker.org/?search=cars&results=20>

O también podría cambiarle los parámetros como en vez de 'cars' que diga 'bikes'.

Vulnerabilidades de Referencias Directas Inseguras a Objetos

Cuando una aplicación web permite la referencia directa a recursos importantes como una DB, archivos y demás según las entradas del usuario. Error producido por la mala sanitización de la entrada del usuario. Se recomienda el uso de la referencia indirecta.

XSS

Ataque de inyección de comandos que se puede dar en una URL como en un campo de entrada de datos. Los tipos de XSS que hay son.

- XSS Reflected.
- XSS Almacenado.
- XSS basado en DOM.

El objetivo de esto es la recopilación de credenciales, cookies, secuestro de sesión y demás.

Ataques XSS Reflejados => se vulnera un servidor y se lo usa para compartir enlaces que cuando el objetivo haga clic en él, le "explote en la cara" el exploit, un ejemplo sencillo de este ataque es el siguiente:

[https://victima.com/search?q=<script>alert\('XSS'\)</script>](https://victima.com/search?q=<script>alert('XSS')</script>)

Ataques XSS Almacenados => estos ataques quedan guardados en el servidor infectado, estos son llevados a cabo en posteos como comentarios, blogs y demás, los cuales quedan permanentemente (salvo que sean borrados por un admin o el usuario que posteo) y cada vez que alguien entre al sitio, les "explotará en la cara" el XSS.

Ataque XSS basado en DOM => el atacante le envía al objetivo una URL maliciosa a la víctima, esta hace clic en el enlace y le puede mostrar un sitio web malicioso o realizar un ataque de DOM que el cliente web procese y ejecute sin que el usuario se dé cuenta.

DOM

Document Object Model, es el esqueleto de una página web. Es una representación jerárquica en forma de árbol que le permite a los navegadores interpretar el contenido de una página HTML (también se aplica a XML y otros formatos estructurados).

Tipos de DOM:

- HTML DOM
- XML DOM
- SVG DOM
- MathML DOM

CSRF/XSRF

XSRF, o Falsificación de Peticiones en Sitios Cruzados, es un ataque donde un atacante engaña a un usuario autenticado para que ejecute acciones no deseadas en una aplicación web en la que ya tiene sesión iniciada. Esto ocurre porque el navegador de la víctima incluye automáticamente sus credenciales (como cookies) en la petición maliciosa del atacante. La aplicación web, al no verificar la fuente de la petición, la ejecuta como si fuera legítima, permitiendo al atacante realizar acciones en nombre del usuario sin su consentimiento explícito.

Las mitigaciones se dan del lado del servidor.

Clickjacking

Este ataque induce a que el objetivo haga clic en alguna función de la página con intenciones “inofensivas” pero el objetivo al hacer clic va a realizar una acción maliciosa como mandarle las cookies de sesión al atacante.

Recorrido de Directorios (Path Traversal)

Esta vulnerabilidad se explota con el punto-punto-barra (../) o usando rutas de archivos absolutas.

Ej:

`http://192.168.78.8:66/vulnerabilidades/fi/?page=../../../../etc/passwd`

En el path traversal anterior, se nos mostrará el contenido del archivo etc/passwd. Es recomendable usar codificación como alternativa para explotar esta vulnerabilidad.

Manipulación de Cookies

También conocidos como ataques basados en DOM, se dan cuando se almacenan en el documento la entrada del usuario y son usadas como respuestas para consultas del mismo DOM. La entrada es procesada del lado del cliente y es por ello que un atacante se puede aprovechar de esto para manipular los valores de la cookie y activar vulnerabilidades basadas en DOM. Por ello se recomienda no usar la escritura dinámica de cookies.

Inclusión de archivos LOCAL (LFI)

Esta vulnerabilidad se da cuando una aplicación deja que un usuario cargue archivos al servidor con el fin de leer o ejecutar código en el sistema de la víctima.

Es una vulnerabilidad crítica si el sistema objetivo/aplicación web se ejecuta como root.

Inclusión de archivos REMOTA (RFI)

Es similar a la anterior con la diferencia que en lugar de acceder a un archivo de la víctima, el atacante ejecuta código alojado en su propio sistema.

Básicamente, en la RFI, la aplicación vulnerable no solo incluye archivos, sino que lo hace desde una URL externa controlada por el atacante. El atacante aloja un script malicioso en su propio servidor y luego manipula la aplicación para que lo incluya y ejecute.

Ej: <http://192.168.78.8:66/vulnerabilities/fi/?page=http://malicious.h4cker.org/malware.html>

Condiciones de Carrera (Race Condition)

Se da cuando un sistema intenta realizar dos operaciones al mismo tiempo, pero de forma original, se deben ejecutar un proceso a la vez; ¿cuál sería el primero en ejecutarse?, según el momento en que fueron mandadas, durante ese lapso de que la “propuesta” para ejecutar el proceso llegue al sistema, el atacante podría aprovechar ese pequeño lapso para ejecutar un script malicioso o servicio malicioso antes de que llegue el servicio verdadero al sistema para ser ejecutado y como el sistema lo espera, piensa que el servicio del atacante es el verdadero y ahí es cuando se da la condición e carrera.